

2 - Threat Modeling

🕒 Created	June 23, 2026 2:26 PM
🏷️ Tags	

Động từ cho STRIDE:

S - Spoofing	giả danh / mạo nhận
T - Tampering	sửa / chèn / tráo
R - Repudiation	chối bỏ "tôi không làm"
I - Information Disclosure	đọc trộm / nghe lén
D - Denial of Service	làm quá tải / làm sập
E - Elevation of Privilege	giành quyền cao hơn

Internet ↔ Gateway

STRIDE	Action	Impact	Likelihood	Mitigation / Countermeasure
S - Spoofing	Hacker tự chế một token giả, ký bằng khóa lạ của nó, gắn vào request để giả danh một user đăng nhập	Cao (Động đến asset token → Backend)	Cao (ai trên Internet cũng gửi request được)	Gateway verify chữ ký token qua JWKS → chữ ký không khớp public key IdP ⇒ trả 401, chặn
T - Tampering	Hacker sửa body của request M2M nhưng giữ nguyên chữ ký HMAC cũ, để tuần dữ liệu độc vào backend	Cao (động đến Backend)	Trung (cần phải bắt được request hợp lệ trước)	Chữ ký HMAC phải bám cả body vào chuỗi ký, chữ ký không khớp ⇒ 401
R - Repudiation	Một service M2M gửi một request gây hại, sau đó chối rằng tôi không	Trung (Gây khó tracking dấu vết)	Cao	Scope quyền chặt chẽ cho audit log, Mỗi request M2M bị KÝ HMAC bằng

STRIDE	Action	Impact	Likelihood	Mitigation / Countermeasure
	gửi, lúc này không có bằng chứng ⇒ Không quy trách nhiệm được			secret RIÊNG của service đó + ghi log. ⇒ nó không chối được. (= non-repudiation)
I - Information Disclosure	Bất cứ ai cũng có thể đọc trộm cũng như nghe lén giao tiếp giữa service/user với backend và có thể lấy access token ngay tại thời điểm đó để mạo danh giao tiếp	Cao (động đến backend)	Thấp ở prod (TLS bật), Cao ở dev (http://localhost)	Luôn phải bật TLS
D - Denial of Service	Hacker bắn hàng loạt request vào gateway cùng một lúc, user thật không truy cập được	Cao (gây tắc nghẽn dịch vụ)	Trung	Áp dụng rate limiting cho gateway
E - Elevation of Privilege	Hacker có token hợp lệ của user do scope cấp, sau đó gọi endpoint chỉ dành cho admin	Cao (Authorization)	Cao	Kiểm scope

Gateway ↔ Backend

STRIDE	Action	Impact	Likelihood	Mitigation / Countermeasure
S - Spoofing	Hacker bằng cách nào đó đứng trong mạng nội bộ và gọi thẳng vào	Cao (Truy cập thẳng vào backend)	Trung (Muốn thực hiện thì phải vào mạng nội bộ trước)	áp dụng zero-trust cho mạng nội bộ: 1- mTLS giữa gateway ↔ backend 2- backend không tin vị trí mạng/IP

STRIDE	Action	Impact	Likelihood	Mitigation / Countermeasure
	api vòng qua gateway			nguồn mà phải xác thực danh tính và scope từ thông tin gateway chuyển tiếp
T - Tampering				
R - Repudiation				
I - Information Disclosure				
D - Denial of Service				
E - Elevation of Privilege	Backend nhận danh tính/quyền từ header gateway chuyển xuống, và nếu backend tin header này vô điều kiện, hacker có thể tự đặt lại header và leo quyền từ user lên admin	Cao (Authorization)	Trung (Muốn thực hiện thì phải vào mạng nội bộ trước)	Backend không tin header danh tính thuần: 1- Tự verify lại token gốc và đọc scope từ đó 2 - gateway ký claim nội bộ, backend verify chữ ký + mTLS (S1) để chắc kết nối đến gateway thật

Gateway ↔ IdP

STRIDE	Action	Impact	Likelihood	Mitigation / Countermeasure
S - Spoofing	Gateway fetch public key từ IdP qua URL, bằng cách nào đó hacker làm cho dns hoặc non-tls, lúc này hacker đánh tráo JWKS và	Cao (thay đổi toàn bộ logic token sau đó)	Cao (hacker có thể truy cập chỉ qua url)	1- xác thực nguồn - chắc chắn đang nói với IdP thật 2- chống sửa giữa đường - không ai chen key lạ vào. Thêm: pin issuer (iss phải khớp IdP đã

STRIDE	Action	Impact	Likelihood	Mitigation / Countermeasure
	nhét public key của nó vào			biết) và cache key, không fetch mù mỗi request
T - Tampering				
R - Repudiation				
I - Information Disclosure				
D - Denial of Service				
E - Elevation of Privilege				

Gateway ↔ Vault

STRIDE	Action	Impact	Likelihood	Mitigation / Countermeasure
S - Spoofing				
T - Tampering				
R - Repudiation				
I - Information Disclosure	Trong trường hợp không mã hóa hoặc cấu hình sai secret/khóa trong Gateway ↔ Vault, ai trong nội bộ cũng có thể xem được khóa	Cao (lộ secret)	Cao (với trường hợp secret không mã hóa hoặc cấu hình sai)	1- TLS giữa gateway ↔ Vault (chống nghe lén) 2- mã hóa at-rest trong Vault 3- least-privilege: mỗi service xác thực riêng, chỉ đọc đúng secret của mình 4- audit log mọi lần truy xuất secret
D - Denial of Service				
E - Elevation of Privilege				